

DISPOSIZIONE DI GRUPPO n. 295/AD del 9 aprile 2021

“Modello di Gestione per la Protezione dei Dati Personali”

Come noto, il 25 maggio 2018 è divenuta obbligatoria l'applicazione del “*Regolamento generale sulla protezione dei dati*” (GDPR o Regolamento UE 2016/679). Il Decreto Legislativo 10 agosto 2018 n. 101, recante norme per l'adeguamento della normativa nazionale al Regolamento UE 2016/679, ha conseguentemente modificato le disposizioni del Codice in materia di protezione dei dati personali D.Lgs. n. 196/2003 (c.d. Nuovo Codice *Privacy*).

Il quadro normativo così delineato ha come principale obiettivo la protezione delle persone fisiche con riguardo al trattamento e alla libera circolazione dei dati personali. In particolare, il GDPR nasce da precise esigenze, come indicato dalla stessa Commissione UE, di certezza giuridica, armonizzazione e maggiore semplicità delle norme riguardanti il trasferimento di dati personali all'interno dell'Unione e la disciplina dei trasferimenti verso altre parti del mondo. Si tratta poi di una risposta, necessaria e urgente, alle sfide poste dagli sviluppi tecnologici e dai nuovi modelli di crescita economica, tenendo conto delle esigenze di tutela dei dati personali sempre più avvertite dai cittadini.

Il primo periodo di applicazione del Regolamento UE 2016/679 ha visto lo sforzo di tutti verso la creazione di un modello di gestione per la protezione dei dati personali, con riflessi importanti sull'operatività delle Società. Il Gruppo si è dotato di un proprio *Framework di Data Protection* definito come “*l'insieme di regole e metodi definiti dal sistema delle norme organizzative, i ruoli e le responsabilità delle strutture coinvolte, i processi e i sistemi informativi, l'insieme dei trattamenti di dati personali per le esigenze di business e operative, il sistema dei controlli rivolto alla gestione e mitigazione dei rischi per i diritti e le libertà delle persone fisiche legati al trattamento di dati personali*”.

Trascorso questo primo periodo di applicazione, si è resa necessaria una revisione complessiva del *Framework* finalizzata a (i) recepire gli approcci interpretativi del Garante per la protezione dei dati personali e dell'*European Data Protection Board*, (ii) semplificare alcuni processi definiti dalle Comunicazioni Organizzative di Gruppo in materia, (iii) applicare *best practice* di settore, (iv) recepire le recenti modifiche organizzative avvenute nel Gruppo. Tale revisione ha previsto, inoltre, l'integrazione, all'interno della presente Disposizione di Gruppo, delle indicazioni relative alle modalità di designazione delle “persone autorizzate al trattamento”.

Si conferma che il Gruppo Ferrovie dello Stato Italiane ha individuato, per la *data protection*, un modello organizzativo di Gruppo di tipo “distribuito”, che prevede, laddove ne sussistano le condizioni, la nomina di un *Data Protection Officer* o Responsabile della protezione dei dati (“DPO” nel seguito) interno alla Società, demandando al DPO di FS SpA l'attività di indirizzo e coordinamento.

Entro 90 giorni dall'emissione della presente Disposizione di Gruppo, le Società del Gruppo che non abbiano già provveduto, sono tenute a identificare e designare una risorsa interna dedicata quale DPO, previa condivisione con il DPO di FS SpA e secondo le modalità riportate nel presente documento. Le Società concordano con il DPO di FS SpA eventuali deroghe al termine sopra indicato dei 90 giorni. Di seguito l'elenco delle Società per le quali è richiesta la designazione:

- Ferrovie dello Stato Italiane SpA
- Trenitalia SpA
- Rete Ferroviaria Italiana SpA
- Anas SpA
- Busitalia – Sita Nord Srl
- Ferrovie del Sud Est e Servizi Automobilistici Srl
- Ferservizi SpA
- Fercredit SpA
- FSTechnology SpA
- Mercitalia Logistics SpA
- NUGO SpA
- Le Società estere soggette ad obbligo di nomina ai sensi dell'Art. 37, Par. 1 del Regolamento

Le Società del Gruppo non incluse nel predetto elenco possono, previa preliminare condivisione con il DPO di FS SpA, designare il DPO laddove, nell'ambito delle autonomie societarie, si ritenga che siano soddisfatte le condizioni normative di cui all'Art. 37, Par. 1 del Regolamento o si intenda procedere alla nomina su base volontaria.

L'Art. 37, Par. 2 del Regolamento prevede la possibilità, per un gruppo imprenditoriale, di nominare un unico DPO *“a condizione che [...] sia facilmente raggiungibile da ciascuno stabilimento”*. L'Art 4, Par. 1, p. 19) del Regolamento definisce gruppo imprenditoriale *“un gruppo costituito da un'impresa controllante e dalle imprese da questa controllate”*. Pertanto, al fine di evitare una eccessiva moltiplicazione dei ruoli, le Società direttamente controllate da FS SpA che si configurino come *sub-holding* ossia Società che a loro volta controllano Società operanti nel medesimo settore di business possono, previa condivisione con il DPO di FS SpA, nominare un DPO che svolga tale compito anche per le controllate.

Nel caso di Società estere, ove presenti le condizioni normative per la nomina del DPO, ai fini di facilitare il dialogo con le rispettive Autorità di controllo locali, è sempre prevista la nomina di un DPO societario.

Il DPO è designato, così come previsto dall'Art. 37, Par. 5, del Regolamento in funzione delle qualità professionali, in particolare della conoscenza specialistica della normativa e delle prassi in materia di protezione dei dati personali, e della capacità di assolvere i compiti di cui all'Art. 39 del Regolamento.

Il DPO, la cui designazione e revoca avviene, su proposta dell'Amministratore Delegato, da parte del Consiglio di Amministrazione, a cui il DPO riporta funzionalmente, dovrà, in coerenza con l'assetto organizzativo della Capogruppo, collocarsi preferibilmente all'interno della funzione legale o, in alternativa, previa condivisione con il DPO di FS SpA e con le competenti strutture in ambito Organizzazione e Processi, in ambiti che non comportino conflitto di interesse con le attività del DPO o ne possano ledere l'autonomia ed indipendenza ex art. art. 38 GDPR.

Il Gruppo FS Italiane, al fine di garantire il presidio sui temi di *data protection* anche nelle Società in cui non è prevista obbligatoriamente la nomina del DPO, ha istituito la figura del Referente *Data Protection*. La nomina del Referente *Data Protection* è prevista anche nelle Società controllate in cui il DPO della controllante svolge tale ruolo per le Società controllate. Il Referente *Data Protection* è nominato dall'Amministratore Delegato (o dall'Amministratore Unico) con specifica Comunicazione Organizzativa.

Le Società del Gruppo sono tenute a recepire nel proprio sistema normativo interno i contenuti della presente Disposizione provvedendo a declinarli nella rispettiva realtà aziendale e adottando proprie Comunicazioni Organizzative in materia. Ciascuna Società garantisce la corretta e costante applicazione di quanto definito e ne assicura la massima diffusione al proprio interno ed il relativo controllo attuativo anche presso le proprie controllate, nel rispetto degli obblighi di riservatezza e delle prerogative di autonomia e indipendenza di ciascuna Società e, in particolare, del Gestore dell'infrastruttura ferroviaria nazionale, così come previsti dalla normativa comunitaria e nazionale. Per le Società estere del Gruppo, direttamente o indirettamente controllate, il recepimento della presente Disposizione è a discrezione del Titolare che valuta, insieme al DPO di FS SpA, l'applicabilità della stessa rispetto al contesto normativo del Paese in cui opera.

A seguito di eventuali modifiche all'assetto societario di Gruppo (acquisizione, fusione, scorporo etc.), le "nuove" entità legali che risultino controllate, direttamente o indirettamente, da FS SpA, sono soggette al recepimento della presente e ad avviare tutte le attività necessarie per un pronto adeguamento.

La presente Disposizione di Gruppo aggiorna e sostituisce la DdG n. 252/AD del 10 maggio 2018 e la Comunicazione Organizzativa n. 540/AD del 26 ottobre 2018.

Firmato
Gianfranco Battisti

1. PREMESSA	5
1.1 CONTESTO NORMATIVO	5
1.2 OBIETTIVI DEL DOCUMENTO	6
2. IL FRAMEWORK DI DATA PROTECTION	7
3. ASSETTO MACRO-ORGANIZZATIVO DELLA DATA PROTECTION	9
3.1 TITOLARE DEL TRATTAMENTO	9
3.2 RESPONSABILE DEL TRATTAMENTO E SUB-RESPONSABILE DEL TRATTAMENTO	9
3.3 IL <i>DATA PROTECTION OFFICER</i>	10
3.3.1 LA FIGURA DEL <i>DATA PROTECTION OFFICER</i> NEL REGOLAMENTO	10
3.3.2 IL <i>DATA PROTECTION OFFICER</i> DI FS SPA	11
3.3.3 IL <i>DATA PROTECTION OFFICER</i> NELLE SOCIETÀ CONTROLLATE DA FS SPA	12
3.4 PERSONE AUTORIZZATE AL TRATTAMENTO	13
3.4.1 IL <i>DATA MANAGER</i>	13
3.4.2 L'INCARICATO	14
3.4.3 L'AMMINISTRATORE DI SISTEMA	15
3.5 IL REFERENTE <i>DATA PROTECTION</i>	16
3.6 FUNZIONI DI SUPPORTO SPECIALISTICO	16
4. LE LINEE DI INDIRIZZO IN MATERIA DI DATA PROTECTION	18
5. FLUSSI INFORMATIVI	19

1. Premessa

1.1 Contesto normativo

Il 27 aprile 2016, il Parlamento ed il Consiglio dell'Unione Europea ("UE" nel seguito) hanno approvato un'importante riforma del quadro normativo relativo alla tutela dei dati personali adottando un pacchetto di riforme¹ che comprende il Regolamento UE 2016/679 "*Regolamento generale sulla protezione dei dati*" (nel seguito "GDPR" o "Regolamento"). Il Regolamento sostituisce la Direttiva 95/46/CE ("Direttiva sulla protezione dei dati") e la sua applicazione è diventata obbligatoria a partire dal 25 maggio 2018, due anni dopo la sua entrata in vigore.

Il nuovo Regolamento rafforza la tutela del diritto alla protezione dei dati personali (*Data Protection*), in linea con il riconoscimento della protezione dei dati personali quale diritto fondamentale dell'UE².

Il Decreto Legislativo 10 agosto 2018 n. 101, recante norme per l'adeguamento della normativa nazionale al Regolamento UE n. 2016/679, ha conseguentemente modificato le disposizioni del Codice in materia di protezione dei dati personali D. Lgs. n. 196/2003 (c.d. Nuovo Codice *Privacy*).

Il Regolamento e le successive modifiche introdotte dal D.Lgs. 101/2018 al D.Lgs. 196/2003 (Nuovo Codice *Privacy*), introducono importanti novità rispetto alla precedente disciplina normativa nazionale, quali, tra le altre:

- **Principio di "accountability"**: il Regolamento promuove la responsabilizzazione dei Titolari e l'adozione di approcci e politiche che tengano conto del rischio che un determinato trattamento di dati personali può comportare per i diritti e le libertà degli interessati (approccio *risk-based*). In virtù di tale principio il Titolare del trattamento mette in atto misure tecniche e organizzative adeguate a garantire, ed essere in grado di dimostrare, che il trattamento dei dati personali è effettuato conformemente al Regolamento.
- **Sistema gestionale per la *Data Protection***: il Regolamento richiede la creazione di un sistema gestionale per la *data protection*. Viene introdotta la figura del "Responsabile della protezione dei dati" (*Data Protection Officer* o DPO), finalizzata a facilitare l'attuazione del Regolamento e con il compito, tra gli altri, di sorvegliare l'osservanza del Regolamento e di fornire il necessario supporto consulenziale nell'adozione del sistema gestionale per la *data protection*.
- **Nuovi diritti per le persone fisiche**: il Regolamento rafforza i diritti degli interessati, quali il diritto alla cancellazione del dato, alla limitazione del trattamento, alla portabilità. Rafforza, inoltre, strumenti quali l'informativa e il consenso garantendo informazioni più chiare e complete sul trattamento, introducendo ad esempio, l'obbligo di riportare nell'informativa all'interessato, il tempo di conservazione dei dati personali.

¹ Il pacchetto di riforme in materia di tutela dei dati personali approvato dall'Unione Europea comprende: (i) il Regolamento (UE) 2016/679 (GDPR) del Parlamento europeo e del Consiglio relativo alla protezione delle persone fisiche con riguardo al trattamento dei dati personali, nonché alla libera circolazione di tali dati e che abroga la direttiva 95/46/CE; (ii) la Direttiva (UE) 2016/680 del Parlamento europeo e del Consiglio relativa alla protezione delle persone fisiche con riguardo al trattamento dei dati personali da parte delle autorità competenti a fini di prevenzione, indagine, accertamento e perseguimento di reati o esecuzione di sanzioni penali, nonché alla libera circolazione di tali dati e che abroga la decisione quadro 2008/977/GAI del Consiglio.

² Art. 8 della Carta dei Diritti fondamentali dell'Unione Europea.

- **Registro dei Trattamenti:** il Regolamento introduce l'obbligatorietà di tenuta di un registro delle attività di trattamento svolte sotto la responsabilità del Titolare. Il Registro è uno degli strumenti a disposizione del Titolare per dimostrare la conformità al Regolamento.
- **Data Protection by design e by default:** è uno dei principi chiave del Regolamento e consiste nel garantire la protezione dei dati fin dalla fase di ideazione e progettazione di un trattamento o di un sistema informativo a supporto del trattamento.
- **Violazione di dati personali (Data Breach):** il Titolare del trattamento dovrà valutare, gestire e mitigare i rischi legati alla violazione dei dati personali, considerando le minacce interne ed esterne. È prevista la notifica di eventuali violazioni di dati personali (*Data Breach*) all'Autorità di controllo e, nei casi più gravi, agli interessati coinvolti.
- **Sanzioni:** il Regolamento attribuisce alle Autorità nazionali di protezione dei dati la possibilità di comminare sanzioni amministrative pecuniarie fino al 4% del fatturato mondiale annuo riferito all'esercizio precedente. Le sanzioni previste dal Regolamento sul piano amministrativo e civilistico (risarcimento del danno, ex Art. 82, Par. 6 del Regolamento), integrano quelle penali previste dai singoli stati membri.

1.2 Obiettivi del documento

In linea con la definizione fornita dal Regolamento all'Art. 4, Par. 1, p.1), per "dato personale" si intende *"qualsiasi informazione riguardante una persona fisica identificata o identificabile ("interessato"); si considera identificabile la persona fisica che può essere identificata, direttamente o indirettamente, con particolare riferimento a un identificativo come il nome, un numero di identificazione, dati relativi all'ubicazione, un identificativo online o a uno o più elementi caratteristici della sua identità fisica, fisiologica, genetica, psichica, economica, culturale o sociale"*.

Il Gruppo Ferrovie dello Stato Italiane, in quanto organizzazione complessa, per le sue finalità di business ed operative svolge importanti trattamenti di dati personali di dipendenti, clienti, fornitori, *business partners* e altre terze parti e, con tale consapevolezza, ha introdotto all'interno del proprio Codice Etico la "protezione dei dati personali" quale principio da tutelare e da perseguire. Il Piano Industriale, inoltre, accelera l'impegno verso lo sviluppo di prodotti e servizi digitali e innovativi di tipo *data-driven*, rendendo ancora più importante il rispetto di tale principio.

È pertanto interesse del Gruppo mantenere e sviluppare il presidio e la protezione dei dati personali, al fine di generare quel rapporto di fiducia che è alla base di ogni iniziativa di successo ed un obbligo che prescinde dalla semplice *compliance* normativa. Per questo motivo, il Gruppo si è dotato di un sistema gestionale per la protezione dei dati personali, cosiddetto "*Framework di Data Protection*" (nel seguito anche "*framework*").

Il *Framework di Data Protection* è costituito dall'insieme di regole e metodi definiti dal sistema delle norme organizzative, i ruoli e le responsabilità delle strutture coinvolte, i processi e i sistemi informativi, l'insieme dei trattamenti di dati personali per le esigenze di *business* e operative, il sistema dei controlli rivolto alla gestione e mitigazione dei rischi per i diritti e le libertà delle persone fisiche legati al trattamento di dati personali.

La presente Disposizione di Gruppo aggiorna il sistema gestionale per la protezione dei dati personali, individuando i principi generali alla base del *framework* e la loro applicazione all'interno del Gruppo, e definisce le modalità per l'identificazione e designazione delle persone autorizzate al trattamento.

2. Il Framework di Data Protection

Il *Framework* di *Data Protection* è fondato sui seguenti principi:

- **Approccio basato sul rischio:** il *framework* prevede l'adozione di processi che tengano conto del rischio che un determinato trattamento di dati personali può comportare per i diritti e le libertà degli interessati. Prevede inoltre la chiara identificazione delle persone autorizzate al trattamento di dati personali e delle relative responsabilità (*accountability*).
- **Modello di controllo distribuito:** nel rispetto della piena autonomia societaria e del sistema dei controlli definiti all'interno del Gruppo FS Italiane, il *framework* prevede, per il ruolo di *Data Protection Officer*, un modello distribuito su tutte le Società del Gruppo con obbligo di nomina, individuando nel *Data Protection Officer* di Ferrovie dello Stato Italiane SpA il ruolo di indirizzo e coordinamento e di sviluppo della famiglia professionale.
- **Modello di controllo su tre livelli:** in coerenza con i modelli di Gruppo e con le *best practice* internazionali, il *framework* prevede tre livelli di controllo:
 - i controlli di primo livello (o di linea), finalizzati ad assicurare la corretta progettazione dei trattamenti nel rispetto dei diritti degli interessati, spettano al *management* e ad ogni livello della struttura organizzativa (c.d. "*persone autorizzate al trattamento*");
 - i controlli di secondo livello, finalizzati a verificare l'osservanza e l'applicazione del Regolamento, attribuiti al *Data Protection Officer*;
 - i controlli di terzo livello, finalizzati a fornire *assurance* indipendente e obiettiva sull'adeguatezza ed effettiva operatività del primo e secondo livello di controllo, attribuiti all'Internal Audit.
- **Creazione di Valore:** le attività previste all'interno del *framework*, concorrono alla creazione di valore per il Gruppo, i clienti, il personale e gli altri *stakeholders*, favorendo il miglioramento continuo dei processi, dei modelli di *governance* e degli strumenti di organizzazione, gestione e controllo in materia di protezione dei dati personali, anche attraverso l'accrescimento nel tempo della cultura del rispetto dei diritti fondamentali dell'individuo.
- **Digitalizzazione dei processi:** il *framework*, al fine di garantire e agevolare la *compliance* al Regolamento, rafforza l'impegno del Gruppo nella dematerializzazione e digitalizzazione dei processi.
- **Partnership:** un rapporto di piena collaborazione con le strutture coinvolte nei processi di trattamento di dati personali e con le strutture di supporto specialistico è prerequisite abilitante per il funzionamento del *framework*.
- **Efficacia ed Efficienza:** le metodologie e gli strumenti per la *data protection* sono orientati a conseguire il pieno rispetto della *compliance* normativa e dei principi fondanti alla base del Regolamento, garantendo allo stesso tempo l'integrazione con i processi aziendali nella ricerca della massima efficienza ed evitando la ridondanza dei controlli.
- **Sviluppo della Famiglia Professionale:** le strutture preposte alla sorveglianza del Regolamento si inseriscono all'interno del più ampio sistema di controllo interno e di gestione dei rischi (SCIGR)

³ di Gruppo e rappresentano il presidio specialistico a tutela dei diritti e delle libertà delle persone fisiche in materia di dati personali. Il miglioramento continuo dei processi di *data protection* richiede un costante sviluppo di conoscenze, capacità e competenze della famiglia professionale e la ricerca di modelli professionali che valorizzino nel tempo il ruolo.

- **Change Management.** il *framework* promuove la cultura della *data protection* all'interno del Gruppo, rendendola pervasiva a tutti i livelli gerarchici. Sono definiti strumenti e processi per comprendere e guidare il cambiamento e gestire l'impatto della transizione imposta dal Regolamento.

Tali principi si sostanziano nella chiara identificazione dei ruoli e delle responsabilità delle figure professionali coinvolte a vario titolo nel trattamento dei dati personali e nelle attività di controllo, e in un sistema di norme che declina tali ruoli e responsabilità negli adempimenti previsti per la *compliance* al Regolamento.

³ L'insieme di strumenti, strutture organizzative, norme e regole aziendali volte a consentire una conduzione dell'impresa sana, corretta e coerente con gli obiettivi aziendali definiti dal CdA, attraverso un adeguato processo di identificazione, misurazione, gestione e monitoraggio dei principali rischi, così come attraverso la strutturazione di adeguati flussi informativi volti a garantire la circolazione delle informazioni.

3. Assetto macro-organizzativo della Data Protection

Il Gruppo FS Italiane ha definito l'assetto macro-organizzativo della *data protection* inteso come l'insieme delle figure professionali che concorrono al trattamento dei dati personali e alle attività di supporto, consulenza e controllo rispetto all'osservanza del Regolamento.

Si riporta di seguito uno schema di sintesi dei principali ruoli previsti dal Regolamento e recepiti all'interno del *framework*. Nei paragrafi successivi viene fornito un approfondimento su ciascun ruolo.

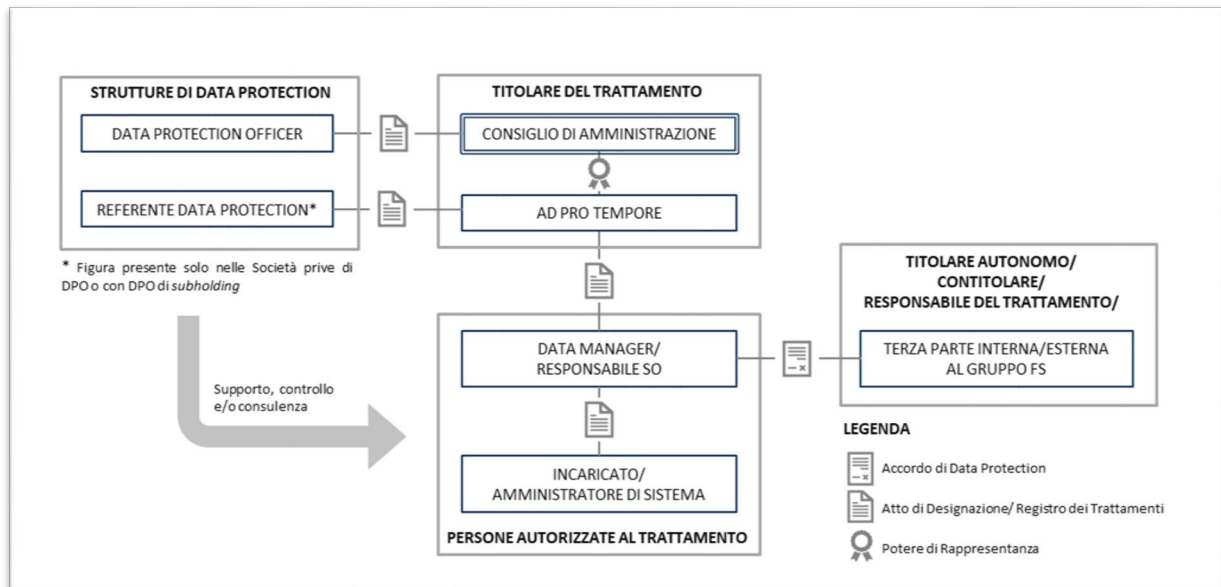


Figura 1 - Assetto macro-organizzativo della *Data Protection*

3.1 Titolare del Trattamento

Il Titolare del Trattamento è la persona fisica o giuridica, la pubblica amministrazione e qualsiasi altro ente, associazione od organismo cui competono le decisioni in ordine alle finalità, alle modalità del trattamento dei dati personali ed agli strumenti utilizzati, ivi compreso il profilo della sicurezza [Art. 4, p. 7) del Regolamento UE 2016/679].

Ogni Società del Gruppo FS Italiane è, quindi, Titolare del Trattamento. Nell'ambito di ciascuna Società, il Titolare del Trattamento è rappresentato dall'AD (o dall'Amministratore Unico), sulla base dei poteri attribuiti dal rispettivo CdA.

3.2 Responsabile del Trattamento e sub-Responsabile del Trattamento

Il Responsabile del Trattamento è la persona fisica o giuridica, l'autorità pubblica, il servizio o altro organismo, esterna all'organizzazione del Titolare, che tratta dati personali per conto del Titolare del Trattamento [Art. 4, p. 8) del Regolamento UE 2016/679]. I trattamenti effettuati da parte di un

Responsabile del Trattamento sono disciplinati da un contratto o da altro atto giuridico (ivi inclusi i trattamenti infragruppo).

Nel caso in cui la Società del Gruppo FS Italiane effettui un trattamento di dati personali per conto di un altro Titolare del Trattamento, il Responsabile del Trattamento è rappresentato dall'AD (o dall'Amministratore Unico) di ciascuna Società, sulla base dei poteri attribuiti dal rispettivo CdA.

Il Responsabile del Trattamento può ricorrere a un altro responsabile, detto sub-Responsabile, previa autorizzazione scritta, specifica o generale, del titolare del trattamento.

Quando un Responsabile del Trattamento ricorre a un sub-Responsabile del Trattamento per l'esecuzione di specifiche attività di trattamento per conto del titolare del trattamento, su tale altro Responsabile del Trattamento sono imposti, mediante un contratto o un altro atto giuridico a norma del diritto dell'Unione o degli Stati membri, gli stessi obblighi in materia di protezione dei dati contenuti nel contratto o in altro atto giuridico tra il Titolare del Trattamento e il Responsabile del Trattamento. Qualora il sub-Responsabile ometta di adempiere ai propri obblighi in materia di protezione dei dati, il Responsabile iniziale conserva nei confronti del Titolare del Trattamento l'intera responsabilità dell'adempimento degli obblighi del sub-Responsabile.

3.3 Il *Data Protection Officer*

3.3.1 La figura del Data Protection Officer nel Regolamento

Il Regolamento disciplina la figura del "Responsabile della protezione dei dati" (*Data Protection Officer* o DPO). La nomina del DPO è obbligatoria nei casi in cui sussistano le condizioni di cui all'Art. 37 del Regolamento. Il DPO può inoltre essere nominato su base volontaria. La designazione di tale figura resta comunque raccomandata, anche alla luce del principio di "accountability".

Il DPO svolge le attività di cui all'Art. 39 di seguito riportate: *"a) informare e fornire consulenza al Titolare del Trattamento o al Responsabile del Trattamento⁴, nonché ai dipendenti della Società che eseguono il trattamento in merito agli obblighi derivanti dal Regolamento, nonché da altre disposizioni nazionali o dell'Unione relative alla protezione dei dati; b) sorvegliare l'osservanza del Regolamento, di altre disposizioni nazionali o dell'Unione relative alla protezione dei dati, nonché delle politiche del Titolare del Trattamento o del Responsabile del Trattamento⁵ in materia di protezione dei dati personali, compresi l'attribuzione delle responsabilità, la sensibilizzazione e la formazione del personale che partecipa ai trattamenti e alle connesse attività di controllo. c) fornire, se richiesto, un parere in merito alla valutazione d'impatto sulla protezione dei dati e sorvegliarne lo svolgimento ai sensi dell'Art. 35 del Regolamento⁶; d) cooperare con l'Autorità di controllo; e) fungere da punto di contatto con l'Autorità di controllo per questioni connesse al trattamento, tra cui la consultazione preventiva di cui all'Art. 36, ed effettuare, se del caso, consultazioni relativamente a qualunque altra questione."*

⁴ Se la Società del Gruppo FS Italiane agisce in qualità di Responsabile del Trattamento.

⁵ Se la Società del Gruppo FS Italiane agisce in qualità di Responsabile del Trattamento.

⁶ Rispetto alla valutazione di impatto (o *Data Protection Impact Assessment*) il DPO può infatti suggerire se condurre o meno la valutazione, quali salvaguardie applicare (comprese misure tecniche e organizzative, per attenuare i rischi per i diritti e le libertà degli interessati), se le conclusioni raggiunte (procedere o meno con il trattamento, e quali salvaguardie applicare) siano conformi al Regolamento, se richiedere il parere degli Interessati, se investire l'Autorità di controllo in presenza di particolari rischi. La responsabilità di effettuare trattamenti in contrasto con il parere espresso dal DPO resta al Titolare, che ne formalizza le motivazioni.

Tali attività sono svolte assistendo il Titolare, i Data Manager e più in generale tutte le figure previste nel framework, nel controllo della *compliance* alla normativa, fermo restando che il rispetto delle norme in materia di protezione dei dati personali fa parte della responsabilità d'impresa del Titolare stesso.

Il DPO opera in modo imparziale e in assenza di condizionamenti che possano limitare o influenzare in qualsiasi modo il corretto svolgimento delle proprie funzioni ed è tenuto ad esprimere liberamente il dissenso nell'ambito del proprio giudizio professionale. È, inoltre, tenuto al segreto e alla riservatezza in merito all'adempimento dei propri compiti, in conformità del diritto nazionale e dell'UE. Per la nomina del DPO sono oggetto di valutazione il profilo del candidato e le caratteristiche di onorabilità, integrità, rispettabilità, indipendenza, professionalità, competenza ed esperienza necessarie, nonché le eventuali incompatibilità, anche in termini di sussistenza e potenziale conflitto di interesse, con attività di trattamento dati presso la Società.

Il DPO è invitato a partecipare su base regolare ai Comitati che possano determinare decisioni con potenziale impatto sulla protezione dei dati e, più in generale, ogni qualvolta debbano essere assunte decisioni che possano comportare rischi per i diritti e le libertà delle persone fisiche in materia di dati personali.

Il Regolamento stabilisce che il DPO può essere un dipendente del Titolare del Trattamento o del Responsabile del Trattamento⁷ oppure assolvere i suoi compiti in base ad un contratto di servizi. Stabilisce, inoltre, che un “gruppo imprenditoriale” può nominare un unico DPO, a condizione che “sia facilmente raggiungibile da ciascuno stabilimento”.

In considerazione del ruolo di sorveglianza attribuito dal Regolamento, volto ad assicurare la corretta gestione ed il controllo dei rischi connessi al trattamento dei dati personali, le funzioni del DPO sono riconducibili ad attività di controllo di secondo livello. Pertanto, il DPO partecipa attivamente al sistema di controllo interno e di gestione dei rischi (SCIGR).

Nel seguito del documento, ove non precisato diversamente, per “Data Protection Officer” (o “DPO”) si intendono indistintamente il DPO di FS SpA e il DPO delle Società controllate, le cui peculiarità in termini di ruolo sono indicate di seguito.

3.3.2 Il Data Protection Officer di FS SpA

Il DPO di FS SpA è nominato dal Consiglio di Amministrazione su proposta del Titolare, rappresentato dall'AD e DG. Il DPO di FS SpA riporta funzionalmente al Consiglio di Amministrazione e la relativa struttura organizzativa è collocata in ambito General Counsel, Affari Societari e Compliance. Il CdA, inoltre, dà mandato all'Amministratore Delegato e Direttore Generale, anche per il tramite delle competenti funzioni aziendali, di porre in essere tutte le azioni necessarie ad assicurare che il DPO di FS SpA disponga di tutte le risorse necessarie al fine di consentire l'ottimale svolgimento dei compiti e delle funzioni assegnate, non sia rimosso o penalizzato in ragione dell'adempimento dei compiti affidati nell'esercizio delle proprie funzioni ed eserciti le proprie funzioni in autonomia e indipendenza.

La nomina del DPO di FS SpA è a tempo indeterminato ed è soggetta a revoca con le stesse modalità previste per la nomina.

Il DPO di FS SpA, oltre ai suddetti compiti stabiliti dal Regolamento, definisce il *Framework* di Data Protection per il Gruppo, cura l'indirizzo e coordinamento delle attività e lo sviluppo della famiglia professionale,

⁷ Se la Società del Gruppo FS Italiane agisce in qualità di Responsabile del Trattamento.

coordina le attività su tematiche di carattere trasversale e su trattamenti infragruppo. Coordina, infine, tutti i contatti con l'Autorità di controllo, al fine di garantire che le tematiche sottoposte all'Autorità non siano già state affrontate a livello di Gruppo e per armonizzare le interlocuzioni su tematiche simili. A tale scopo, è sempre previsto il coinvolgimento del DPO di FS SpA nei seguenti casi:

- DPIA per le quali sia richiesto un parere dell'Autorità di controllo;
- esercizio dei poteri di indagine, correttivi, autorizzativi e consultivi da parte del Garante per la Protezione dei Dati Personali;
- segnalazioni relative a *data breach*;
- ogni altra questione per cui sia necessario il coinvolgimento del Garante per la Protezione dei Dati Personali.

Infine, nel caso in cui al trattamento dei dati personali concorrano più Società del Gruppo, il DPO di FS SpA viene interessato per il coordinamento delle attività dei diversi DPO societari, ove designati ovvero dei Referenti data protection societari, al fine di garantire il corretto esercizio dei diritti degli interessati nel caso di trattamenti infragruppo.

3.3.3 Il Data Protection Officer nelle Società controllate da FS SpA

Oltre che in FS SpA, la *governance* della *Data Protection* stabilisce la presenza del DPO nelle Società controllate per le quali vi è obbligo normativo di nomina del DPO ai sensi dell'Art.37 del Regolamento o per le Società che volontariamente, in ragione della rilevanza, le finalità e i volumi dei trattamenti, decidano di nominare un DPO societario (modello di controllo distribuito).

La nomina e la revoca del DPO societario seguono regole analoghe a quelle previste per il DPO di FS SpA. Analogamente, infatti, il DPO della Società riporta funzionalmente al Consiglio di Amministrazione⁸ e dal punto di vista organizzativo è collocato, preferibilmente, all'interno della funzione legale o, in alternativa, previa condivisione con il DPO di FS SpA, e con le competenti strutture in ambito Organizzazione e Processi, in ambiti che non comportino conflitto di interesse con le attività del DPO o ne possano ledere l'autonomia e l'indipendenza ex art. 38 GDPR.

Il DPO della Società controllata supporta il Titolare nel recepimento e nell'attuazione del sistema di norme di Gruppo definito dal DPO di FS SpA, coordinandosi con lo stesso per le verifiche di coerenza e per ogni necessario supporto consulenziale.

Nel caso in cui la Società non avesse già provveduto alla nomina di un DPO interno, solo in via transitoria e fino all'individuazione del medesimo, il DPO di FS SpA svolge tale ruolo in *service* per le Società del Gruppo con obbligo di nomina. Le attività di *Data Protection*, ancorché svolte mediante *service*, ricadono nell'ambito delle prerogative proprie delle Società controllate di riferimento e dei relativi Titolari. Alle Società controllate competono in via esclusiva la definizione, l'attuazione e il monitoraggio delle conseguenti iniziative di miglioramento.

L'Art. 37 del Regolamento prevede la possibilità, per un gruppo imprenditoriale, di nominare un unico DPO "*a condizione che [...] sia facilmente raggiungibile da ciascuno stabilimento*". L'Art 4, 19) del Regolamento definisce gruppo imprenditoriale "*un gruppo costituito da un'impresa controllante e dalle imprese da questa controllate*". Pertanto,

⁸ Per quanto attiene l'inquadramento organizzativo del DPO nelle Società controllate valgono le valutazioni espresse nei paragrafi precedenti.

al fine di evitare una eccessiva moltiplicazione dei ruoli, le Società direttamente controllate da FS SpA che si configurino come *sub-holding*, ossia Società che a loro volta controllano Società operanti nel medesimo settore di business possono, previa condivisione con il DPO di FS SpA, nominare un DPO che svolga tale compito anche per le controllate.

Nel caso di Società estere, ove presenti le condizioni normative per la nomina del DPO, ai fini di facilitare il dialogo con le rispettive Autorità di controllo locali, è sempre prevista la nomina di un DPO societario.

3.4 Persone autorizzate al trattamento

Le Società del Gruppo FS Italiane, in quanto organizzazioni aziendali complesse chiamate a gestire una molteplicità di trattamenti di dati personali, necessitano di un sistema di deleghe da parte del Titolare del Trattamento. Il Titolare, infatti, pur rimanendo responsabile delle attività di trattamento e dell'osservanza del Regolamento, identifica, per il tramite dell'Amministratore Delegato, le “*persone autorizzate al trattamento*”: i *Data Manager*, gli Incaricati e gli Amministratori di Sistema.

Con particolare riferimento al ruolo di *Data Manager*, l'Amministratore Delegato si avvale dei responsabili delle strutture organizzative a suo diretto riporto, che sulla base dell'organizzazione interna, delle competenze professionali e della responsabilità sulle attività di trattamento, potranno acquisire direttamente il ruolo di *Data Manager* o delegarlo ad altri responsabili all'interno della struttura organizzativa di cui hanno la responsabilità.

I responsabili gerarchici dei *Data Manager* sono, per definizione, “*persone autorizzate al trattamento*” ai sensi della normativa in materia di protezione dei dati personali. In virtù di tale ruolo gerarchico nei confronti del *Data Manager*, infatti, hanno il compito di supervisionare le attività di trattamento e l'applicazione del *framework* di *data protection* per tutti i trattamenti svolti nell'ambito della struttura organizzativa di cui hanno la responsabilità.

3.4.1 Il Data Manager

Tra le persone autorizzate al trattamento, il *Data Manager* è la figura con ruolo di coordinamento, determinazione e valutazione della necessità, delle finalità e dei mezzi del trattamento di dati personali.

Appurate le competenze, le capacità e l'affidabilità degli stessi, quali *Data Manager* sono individuati i responsabili delle strutture organizzative nelle cui aree di competenza ricadono i trattamenti di dati personali individuati nel “Registro dei trattamenti”. Ad ogni trattamento è associato univocamente un *Data Manager*, mentre un *Data Manager* può avere responsabilità su più trattamenti.

Il *Data Manager* è designato/revocato⁹ dall'Amministratore Delegato, in coerenza con le responsabilità organizzative attribuite e su indicazione dei suoi riporti gerarchici. Il DPO, per conto del Titolare, comunica l'avvenuta designazione/revoca alla competente struttura HR societaria. La designazione/revoca avviene mediante lo strumento informatico “Registro dei Trattamenti” accessibile dalla intranet aziendale. Un elenco aggiornato dei *Data Manager* è pubblicato, almeno semestralmente, sulla intranet aziendale per facilitarne la consultazione. Resta inteso che l'elenco ufficiale dei *Data Manager* è quello disponibile sul Registro dei Trattamenti, aggiornato nel continuo.

⁹ La revoca può avvenire su indicazione dei riporti gerarchici dell'AD o in base a eventuali variazioni di titolarità formalizzate dalle disposizioni organizzative.

In quanto persone autorizzate al trattamento, le istruzioni a cui il *Data Manager* deve attenersi sono quelle definite dal Titolare nell'ambito del *framework*. In sintesi, i principali compiti attribuiti al *Data Manager* sono i seguenti:

- stabilire, sulla base delle esigenze di *business*/operative, la necessità di trattare dati personali, assicurando sin dalla progettazione del trattamento il rispetto dei principi chiave del Regolamento (minimizzazione, limitazione della conservazione, etc.);
- effettuare le valutazioni sui rischi per i diritti e le libertà delle persone fisiche derivanti dalle attività di trattamento, tenendo conto della natura, dell'ambito di applicazione, del contesto e delle finalità degli stessi (c.d. *Data Protection Impact Assessment*);
- mettere in atto misure tecniche e organizzative adeguate al rischio e idonee a garantire il rispetto dei diritti degli interessati;
- adottare misure finalizzate a fornire all'interessato tutte le informazioni connesse al trattamento dei suoi dati personali ed attivarsi al fine di agevolare la tempestiva risposta alle richieste di esercizio dei diritti da parte dei medesimi;
- concorda con il Titolare, sulla base delle finalità del trattamento, l'eventuale opportunità di avvalersi di soggetti terzi (Responsabili del Trattamento), ivi comprese le altre Società del Gruppo FS Italiane, per il trattamento dei dati personali;
- concorda con il Responsabile, sulla base delle finalità del trattamento, l'eventuale opportunità di svolgere trattamento di dati personali per conto di soggetti terzi, ivi comprese le altre Società del Gruppo FS Italiane;
- collaborare, ove richiesto, con le strutture competenti (DPO e *Cyber Security*) nel processo di *Data Breach Management* in caso di violazione della riservatezza, integrità e disponibilità dei dati personali (*data breach*);
- previa valutazione delle caratteristiche di esperienza, capacità e affidabilità delle persone autorizzate, individuare gli incaricati, fornendo loro istruzioni specifiche circa il perimetro e le modalità di trattamento.

Si specifica che il *Data Manager* per sottoscrivere Accordi di Data Protection sia nel ruolo di Titolare sia nel ruolo di Responsabile deve essere dotato di apposita procura. Nel caso in cui il *Data Manager* non ne fosse dotato interesserà il responsabile gerarchico dotato di procura.

Per gli organismi collegiali e per le iniziative progettuali che prevedono la costituzione di gruppi di lavoro trasversali (ad es., Collegio Sindacale, Comitati consiliari, Comitati aziendali, Gruppi di Lavoro su iniziative specifiche, etc.), il *Data Manager* è identificato nel responsabile della segreteria tecnica dell'organismo oppure nel responsabile della funzione di coordinamento dell'organismo (ad esempio il Presidente). Per l'Organismo di Vigilanza¹⁰ il *Data Manager* è identificato nel Presidente. I membri dell'organismo collegiale che trattano dati personali andranno individuati come incaricati (si veda paragrafo successivo).

3.4.2 L'incaricato

¹⁰ "Parere sulla qualificazione soggettiva ai fini privacy degli Organismi di Vigilanza previsti dall'art. 6, d.lgs. 8 giugno 2001, n. 231" del Garante per la Protezione dei Dati Personali del 21 maggio 2020.

L'incaricato è la persona fisica che, in relazione ad uno specifico trattamento, è autorizzato a effettuare operazioni sui dati personali. L'incaricato è designato dal *Data Manager* nell'ambito delle strutture dallo stesso gerarchicamente dipendenti o funzionalmente collegate¹¹.

La designazione degli incaricati e la consegna delle istruzioni sulle attività di trattamento avvengono con le modalità stabilite dal DPO e consultabili nella sezione *Data Protection* della intranet aziendale. La designazione degli incaricati è un atto formale che richiede un meccanismo di presa visione da parte dell'incaricato, ad esempio, una firma dell'atto di designazione o un *flag* di presa visione su un sistema IT. Incaricati che svolgono la medesima attività di trattamento ricevono le medesime istruzioni.

Gli atti di designazione e le istruzioni conferite devono essere conservati dal *Data Manager* in formato elettronico o cartaceo, in modalità tali da garantire la tracciatura della data di presa visione e un'agevole consultazione in caso di verifica del DPO, organi di controllo interno (audit) o dell'Autorità di Controllo.

3.4.3 L'Amministratore di Sistema

L'Amministratore di Sistema è la figura professionale dedicata alla gestione e alla manutenzione di impianti di elaborazione (sistemi informativi) con cui vengono effettuati trattamenti di dati personali, compresi i sistemi di gestione di: basi di dati, servizi (ad es. *cloud*), sistemi *software* complessi, reti locali, apparati di sicurezza, etc. nella misura in cui consentano di intervenire sui dati personali. Per ogni trattamento possono esserci più Amministratori di Sistema in funzione delle operazioni svolte.

L'Amministratore di Sistema, se dipendente della Società, è designato dal Responsabile della struttura organizzativa¹² nell'ambito della quale è chiamato a svolgere le suddette attività¹³. Se l'Amministratore di Sistema è un dipendente dell'*outsourcer*, la designazione deve essere effettuata dall'*outsourcer* stesso, sulla base di quanto definito negli Accordi di *Data Protection*. La designazione degli Amministratori di Sistema e la consegna delle istruzioni sulle attività specifiche avvengono con le modalità stabilite dal DPO e consultabili nella sezione *Data Protection* della intranet aziendale.

Le strutture organizzative nell'ambito delle quali sono nominati gli Amministratori di Sistema tengono copia aggiornata dell'elenco degli Amministratori di Sistema e dei relativi atti di designazione corredati dalle istruzioni, in modalità tali da garantire il tracciamento della data di presa visione e un'agevole consultazione in caso di verifica del DPO o dell'Autorità di Controllo.

¹¹ Per "collegamento funzionale" si intende un ruolo all'interno di un processo stabilito dal *Data Manager* senza che l'incaricato sia gerarchicamente dipendente dallo stesso.

¹² La figura del Responsabile della struttura organizzativa può coincidere oppure non coincidere con quella di *Data Manager*.

¹³ In considerazione del ruolo svolto da FSTechnology – quale Società del Gruppo FS Italiane deputata garantire il presidio delle architetture, delle infrastrutture e delle tecnologie di riferimento, nonché lo sviluppo, la conduzione e l'esercizio delle applicazioni, la gestione della rete TLC, la sicurezza logica – per le Società che hanno contratti di servizio con FSTechnology, gli Amministratori di Sistema risiedono generalmente all'interno di FSTechnology. Per le Società che mantengono un presidio IT, gli Amministratori di Sistema risiedono generalmente all'interno delle strutture di presidio IT.

3.5 Il Referente *Data Protection*

Il Gruppo FS Italiane, al fine di garantire il presidio sui temi di *data protection* anche nelle Società in cui non è prevista obbligatoriamente la nomina del DPO, ha istituito la figura del Referente *Data Protection* che supporta il Titolare e i *Data Manager* nelle attività operative di adempimento normativo.

La nomina del Referente *Data Protection* è prevista anche nelle Società in cui il DPO di FS SpA svolge tale ruolo in *service* (transitoriamente e fino alla nomina del DPO societario) e nelle Società in cui il DPO di *sub-holding* svolge tale ruolo anche per le Società controllate.

Il Referente *Data Protection* è dotato di una conoscenza approfondita del Regolamento UE/2016/679 e dell'attuale quadro normativo in materia di *Data Protection* e deve supportare il Titolare e i *Data Manager* nelle attività operative di adempimento normativo. Rientrano fra questi adempimenti, in maniera non esaustiva i seguenti:

- a) supportare il Titolare e/o i *Data Manager* nella redazione delle informative;
- b) supportare il Titolare e/o i *Data Manager* nelle attività connesse all'esercizio dei diritti dell'interessato;
- c) supportare il Titolare e/o i *Data Manager* nella redazione degli accordi di *Data Protection* con i Responsabili esterni del Trattamento;
- d) partecipare ai tavoli di lavoro relativi alle attività di *Data Protection Impact Assessment*;
- e) nel caso di DPO di FS SpA in *service* o di *subholding*, fungere da punto di riferimento per il DPO per tutte le attività legate alla sorveglianza sull'applicazione del Regolamento.

Più in generale, ferme restando le responsabilità del Titolare per l'applicazione del Regolamento, il Referente *Data Protection* supporta il Titolare e i *Data Manager* nell'assicurare modalità operative e flussi informativi in coerenza con le Linee di Indirizzo in materia di *data protection*.

I Referenti per la *Data Protection* sono nominati dagli AD delle Società con Comunicazione Organizzativa.

3.6 Funzioni di supporto specialistico

Il *framework* prevede che, ove richiesto dalle specificità del trattamento di dati personali, il DPO possa attivare supporti specialistici, tra cui, in particolare, i seguenti:

- *Cyber Security* (DCPA) di FS SpA, per il tramite del DPO di FS SpA, che fornisce supporto specialistico in materia di sicurezza informatica e in caso di violazione della riservatezza, integrità e disponibilità dei dati personali (*data breach*).
- Legale Lavoro (DCRUO) di FS SpA, per il tramite del DPO di FS SpA, che fornisce supporto specialistico in materia di normativa giuslavoristica per la definizione di linee guida di Gruppo per l'applicazione della normativa di riferimento anche ai fini di un'omogenea interpretazione della stessa, nonché rispetto ad eventuali iniziative da assumere nell'ambito di procedimenti giudiziari, di cui si abbia formale notizia, in cui siano richiamate direttamente o indirettamente eventuali violazioni ai diritti e alle libertà delle persone fisiche in materia di protezione di dati personali.
- Funzioni di *Compliance* di FS SpA e/o societarie, che forniscono supporto specialistico e pareristica in materia di *compliance* normativa e per le verifiche di conformità anche con riferimento all'assetto complessivo della *compliance* aziendale.

- Funzioni Civile e Amministrativo e Penale di FS SpA e/o societarie, che forniscono supporto specialistico e pareristica in materia civile e amministrativa e penale.
- Funzioni di *Risk Management* di FS SpA e/o societarie, ove definite, nel caso in cui i rischi collegati al trattamento di dati personali abbiano un impatto rilevante per la Società.
- FS Technology SpA o presidi IT societari, che forniscono supporto specialistico in materia di sistemi IT.

4. Le linee di indirizzo in materia di Data Protection

Il DPO di FS SpA, nell'ambito delle proprie attività di indirizzo e coordinamento, con il supporto specialistico delle strutture individuate al Par. 3.6, ha definito un sistema di norme interne che declina i ruoli, responsabilità, i processi e le metodologie della *data protection*. Tale sistema di norme si integra coerentemente con l'impianto normativo esistente e, in particolare, con le norme interne relative alla protezione della confidenzialità dell'informazione, di cui alla Disposizione di Gruppo in materia di "*Linee di indirizzo per la classificazione delle informazioni in termini di riservatezza*".

Il sistema delle norme che definiscono il *framework*, consta delle linee di indirizzo relative ai seguenti aspetti:

- **"Data Protection by Design & by Default"**: le linee di indirizzo disciplinano le regole per l'applicazione preventiva dei principi di *data protection* nel disegno e nell'esecuzione di qualsiasi attività che comporti il trattamento di dati personali (*by design* e *by default*).
- **"Identificazione dei Trattamenti a potenziale rischio elevato e Data Protection Impact Assessment"**: le linee di indirizzo disciplinano la metodologia e il processo con cui vengono identificati i trattamenti a potenziale rischio elevato e viene effettuata la valutazione di impatto.
- **"Gestione dei Diritti degli Interessati"**: le linee di indirizzo disciplinano le modalità con cui è garantito agli interessati l'esercizio dei diritti previsti dal Regolamento e i processi aziendali volti ad assicurare una pronta e completa risposta alle richieste degli stessi.
- **"Gestione delle Terze Parti"**: le linee di indirizzo disciplinano le modalità per tutelare i diritti degli interessati in tutte le attività svolte da terze parti che comportano un trattamento di dati personali, definendo i vincoli contrattuali necessari.
- **"Periodo di conservazione dei dati personali"**: le linee di indirizzo disciplinano le modalità e i criteri per l'individuazione del periodo di conservazione dei dati personali. Vengono inoltre dettagliate le attività da porre in essere per garantire l'effettiva cancellazione, l'anonimizzazione o la conservazione ai fini di archiviazione nel pubblico interesse, di ricerca scientifica o storica o a fini statistici del dato personale una volta raggiunto il termine del periodo di conservazione.
- **"Gestione dei Data Breach"**: le linee di indirizzo disciplinano le regole e le indicazioni operative per individuare le violazioni dei dati personali e per garantire il governo e l'attuazione del processo di gestione delle violazioni dei dati personali.

Il *framework* così definito potrà essere integrato o aggiornato a seguito di evoluzioni normative o sostanziali cambiamenti organizzativi, nonché del consolidarsi di *best practice*.

5. Flussi informativi

In attuazione del proprio ruolo di verifica dell'osservanza del Regolamento e consulenza al Titolare e ai *Data Manager*, il DPO realizza uno scambio continuo di informazioni con tutte le strutture, indipendentemente dal livello gerarchico, che concorrono al trattamento di dati personali (flussi informativi *day-by-day*). In affiancamento a tali flussi "informali", il *framework* prevede i seguenti flussi informativi:

- Relazione annuale al Consiglio di Amministrazione: in virtù del riporto funzionale al CdA, il DPO invia almeno annualmente al CdA una relazione sulle attività di *data protection*.
- Relazioni "straordinarie" al Consiglio di Amministrazione: in tutte le occasioni in cui il DPO ritenga opportuno informare il CdA rispetto a circostanze straordinarie che comportino la possibile violazione dei diritti e delle libertà delle persone fisiche in materia di *data protection*, oppure su richiesta del CdA stesso.
- Relazione trimestrale all'Amministratore Delegato: il DPO invia trimestralmente all'Amministratore Delegato, in quanto rappresentante del Titolare del Trattamento, una relazione sulle attività di *data protection*.
- Relazioni "straordinarie" all'Amministratore Delegato: in tutte le occasioni in cui il DPO ritenga opportuno informare l'AD rispetto a circostanze straordinarie che comportino la possibile violazione dei diritti e delle libertà delle persone fisiche in materia di *data protection*, oppure su richiesta dell'AD stesso.
- Relazioni verso eventuali ulteriori Comitati e/o Organismi indipendenti che dovessero farne richiesta.
- Relazione annuale del DPO societario verso il DPO di FS SpA.